

Mapeo de indicadores GQM a requisitos normativos (alto nivel)

Indicador / Métrica	Función CSF 2.0	Ejemplos NIST CSF 2.0 relevantes	Normativa / marcos relacionados (alto nivel)
% cuentas alto riesgo con MFA	PR	PR.AA: gestión de identidades y autenticación fuerte	ENS (control de acceso); ISO/IEC 27001 A.5, A.8; NIS2 (gestión de acceso)
Variación cobertura MFA	PR	PR.AA	ISO/IEC 27004 (medición de seguridad); marcos GRC
MTTD incidentes graves (horas)	DE	DE.CM: monitoreo continuo; DE.DP: detección de eventos	ENS (detección de intrusiones); ISO/IEC 27035; NIS/NIS2 (detección y notificación)
Tendencia MTTD (%)	DE	DE.CM, DE.DP	ISO/IEC 27004; guías de métricas de incidentes
% servicios críticos que cumplen RTO	RC	RC.RP: planes de recuperación; RC.IM: pruebas	ISO 22301 (continuidad); ENS (continuidad del servicio); DORA (resiliencia operativa digital)
Evolución % cumplimiento RTO	RC	RC.RP, RC.IM	ISO 22301; marcos sectoriales de continuidad
% activos detectados automáticamente	ID	ID.AM: inventario de activos	ENS (inventario de activos); ISO/IEC 27001 A.5, A.8
Nº activos huérfanos detectados	ID	ID.AM	Buenas prácticas de CMDB; ITIL
% proveedores críticos con cláusulas de ciberseguridad	GV.SC	GV.SC: gestión de riesgo de cadena de suministro	NIS2 (cadena de suministro); DORA; ISO/IEC 27036
Nº contratos críticos revisados/año	GV.SC	GV.SC	ENS (relaciones con terceros); marcos de SCRM
% objetivos de riesgo con KPIs definidos	GV	GV.RM, GV.RR: estrategia y gestión del riesgo	ISO/IEC 27001 cl. 6 (planificación); COSO ERM; ENS (gestión de riesgos)

Frecuencia de revisión de estrategia (años)	GV	GV.OV, GV.PO: supervisión y política	ISO/IEC 27001 cl. 9 (revisión por la dirección); ENS (revisión)
% repositorios de datos con propietario	ID	ID.IM: gestión de información; GV.OC	RGPD (responsables del tratamiento); ENS; ISO/IEC 27001 (propietarios de activos)
% plantilla con formación anual	PR	PR.AT: concienciación y formación	ENS (formación); ISO/IEC 27001 A.6; NIS2 (formación)
Tasa de clic en simulaciones de phishing	PR	PR.AT	Buenas prácticas en formación; marcos de concienciación
% incidentes gestionados según plan	RS	RS.PO, RS.CO, RS.AN: planificación y análisis de respuesta	ISO/IEC 27035; ENS (gestión de incidentes); NIS2
Tiempo medio de contención (horas)	RS	RS.AN, RS.MI: mitigación y análisis	ISO/IEC 27035; métricas de incidentes (ISO/IEC 27004)